SHALL be treated as single-factor. Otherwise, verification of the output from a multi-factor cryptographic authenticator indicates that the activation factor was used.

3.1.7.3. Usage With Subscriber-Controlled Wallets

A specific form of multi-factor cryptographic authentication is a subscriber-controlled wallet on the subscriber's device, as described in Sec. 5 of [SP800-63C]. After the claimant first unlocks the wallet using an activation factor, the authentication process uses a federation protocol, as detailed in [SP800-63C]. The assertion contents and presentation requirements of the federation protocol provide the security characteristics required of cryptographic authenticators. As such, subscriber-controlled wallets on the subscriber's device can be considered multi-factor authenticators through the activation factor and the presentation and validation of an assertion generated by the wallet.

> Cloud-hosted wallets are not considered cryptographic multi-factor authenticators because access is maintained through authentication over the internet rather than locally. All authentication information from hosted wallets is treated as an assertion, as addressed in Sec. 5 of [SP800-63C].

Access to the private key **SHALL** require an activation factor. Authenticator activation secrets **SHALL** meet the requirements of Sec. 3.2.10. Biometric activation factors **SHALL** meet the requirements of Sec. 3.2.3, including limits on the number of consecutive authentication failures. The password or biometric sample used for activation and any biometric data derived from the biometric sample **SHALL** be erased immediately after an authentication transaction.

Authentication processes using subscriber-controlled wallets **SHALL** be used with a federation process as detailed in Sec. 5 of [SP800-63C]. Signed audience-restricted assertions that are generated by subscriber-controlled wallets are considered phishing-resistant because they prevent an assertion presented to an impostor RP from being used by the legitimate one. Assertions that lack a valid signature from the wallet or an audience restriction **SHALL NOT** be considered phishing-resistant. Assertions **SHALL** also include sufficient information to determine the nature of the activation method used to activate the wallet.

3.1.7.4. Syncable Authenticators

Some cryptographic authenticators allow the subscriber to copy (i.e., clone) the authentication secret to additional devices, usually via a sync fabric. This eases the burden for subscribers who want to use additional devices to authenticate. Specific requirements for syncable authenticators and the sync fabric are given in Appendix B.

3.2.5. Phishing Resistance

Phishing attacks, previously referred to in SP 800-63B as "verifier impersonation," are attempts by fraudulent verifiers and RPs to fool an unwary claimant into presenting an authenticator to an impostor. In some prior versions of SP 800-63, protocols that are resistant to phishing attacks were also referred to as "strongly MitM-resistant."

In this document, phishing resistance is the ability of the authentication protocol to prevent the disclosure of authentication secrets and valid authenticator outputs to an impostor verifier (i.e., an attacker fraudulently posing as the verifier) without relying on the vigilance of the claimant. How the claimant is directed to the impostor verifier is not relevant. For example, regardless of whether the claimant was directed there via search engine optimization or prompted by email, it is considered to be a phishing attack.

Approved cryptographic algorithms **SHALL** be used to establish phishing resistance where required. Keys used for this purpose **SHALL** provide at least the minimum security strength specified in the latest revision of [SP800-131A] (i.e., 112 bits as of the date of this publication).

Phishing resistance requires single- or multi-factor cryptographic authentication. Authenticators that involve the manual entry of an authenticator output (e.g., out-of-band and OTP authenticators) **SHALL NOT** be considered phishing-resistant because the manual entry does not bind the authenticator output to the specific session being authenticated. For example, an impostor verifier could relay an authenticator output to the verifier and successfully authenticate.

Two methods of phishing resistance are recognized: channel binding and verifier name binding. Channel binding is considered more secure than verifier name binding because it is not vulnerable to the misissuance or misappropriation of verifier certificates, but both methods satisfy the requirements for phishing resistance.

3.2.5.1. Channel Binding

An authentication protocol with channel binding **SHALL** establish an authenticated protected channel with the verifier. The protocol **SHALL** then strongly and irreversibly bind a channel identifier negotiated in establishing the authenticated protected channel to the authenticator output (e.g., by signing the two values together using a private key controlled by the claimant for which the public key is known to the verifier). The verifier **SHALL** validate the signature or other information used to prove phishing resistance. This prevents an impostor verifier — even one that has obtained a certificate that represents the actual verifier — from successfully relaying that authentication on a different authenticated protected channel.

An example of a phishing-resistant authentication protocol that uses channel binding is client-authenticated TLS [RFC8446] in which the client signs the authenticator output along with earlier messages from the protocol that are unique to the particular TLS